

Memo to John Kasket

Edith Cruz

Department of Computer Science, Cal State University, Fullerton

CPSC 253: Cybersecurity Foundations and Principles

Mr. Michael Franklin

May 4, 2025

To: John Kasket,

From: Edith Cruz

Date: 05/04/2025

Subject: Policy Review Updates

Hey John,

While I was getting ready to start the cloud migration project, I looked at ACME's existing policies. I would like to suggest some changes to our policies so we can bolster the security of our facility and the data we handle.

For the password policy I think it would be best to follow CISA recommendations and enforce the creation and usage of longer passwords. Frankly I think that our Single Factor Password Configuration Standards are too low and should be stricter than the Multifactor Password Configuration Standards. Our passwords for both Single Factor and Multifactor Password Configuration Standards should enforce passwords that are at least 8 characters long and the usage of all four-character classes. Even if they fall short of the 12 length passwords recommended by CISA, their complexity should make them hard to crack. Additionally, I think going for a year without changing passwords is too long. They should be changed with more frequency from 2-4 times a year. I leave this up to your discretion on what you think best.

I would also like to comment on the data privacy policy. This one and the other two policies have not been updated since 2017. Given technological advancements, I think issues like data retention and working from home should also be addressed. On the issues of data retention, how long should our company hold onto employee information. We can look at SHRM's Federal

Record Retention Policy for guidelines on how we can revise our own policy. For example, regarding selection, hiring and employment records, and background checks the retention period is 1 year. For payroll records, time sheets/cards and Form 1-9, the retention period is 3 years. Other things like employee benefits, tax records, and health and safety records are retained anywhere from 4-6 years.

I investigated teleworking policies related to retention and found the U.S. Department of Commerce's Telework and Remote Work Policy. I believe it would be great if we were more explicit in the wording of the data privacy policy and state that remote work data will also be held to the same standards. Having remote work being acknowledged and addressed on paper would symbolize ACME keeping up with the times.

The third policy I reviewed was our cybersecurity policy. I think that if research is given permission to handle malicious software and systems which do not adhere to security standards, then we need some basic guidelines. Something like ensuring that this research is done in isolated environments so that the rest of the system and network is not affected by any errors. I would also like to add that for the approval of network appliances, a ticket can be submitted first which must then be approved by Unit's IT Lead and perhaps require coordination with finance. This way approval is logged as well as the equipment. I would also like to request that there be a similar process implemented for equipment requests that fall under the classification of endpoints. Those being ACME issued laptops, phones, and desktops. Although in this case, it would require first the approval of a user's supervisor and then the approval of an IT lead with a proper request on why the equipment is necessary and conducive to their work. This way we can ensure that the budget isn't blown through quickly. To enforce all of these changes, I would like to add a final addendum to the cybersecurity policy. I request that there be yearly training on

these policies. Failure to complete these training courses may lead to a suspension of work accounts and access to ACME's network and system. I have attached revised versions of the password, data privacy, and cybersecurity policies. Thank you for reading through all of this and I hope to create a safer environment for ACME with you.

References

Federal record retention requirements. Society for Human Resource Management. (n.d.).

<https://www.shrm.org/content/dam/en/shrm/topics-tools/legal-compliance/Federal-Record-Retention-Requirements.pdf>

Require strong passwords: CISA. Cybersecurity and Infrastructure Security Agency CISA. (n.d.).

<https://www.cisa.gov/secure-our-world/require-strong-passwords>

U.S. DEPARTMENT OF COMMERCE TELEWORK AND REMOTE WORK POLICY. U.S.

DEPARTMENT OF COMMERCE . (2025, April 22).

[https://www.commerce.gov/sites/default/files/2025-](https://www.commerce.gov/sites/default/files/2025-04/DOC%20Telework%20and%20Remote%20Work%20Policy%20%2804-21-25%29_1.pdf)

[04/DOC%20Telework%20and%20Remote%20Work%20Policy%20%2804-21-25%29_1.pdf](https://www.commerce.gov/sites/default/files/2025-04/DOC%20Telework%20and%20Remote%20Work%20Policy%20%2804-21-25%29_1.pdf)